Vertrag zur Auftragsverarbeitung

Lymbe AI · Fassung 1.7 · Art. 28 DSGVO

Exemplar	Christian Gudermann, 26lab.io – Unterschrift unter Anlage 5
Erstellt von	Flubber Pixels UG (haftungsbeschränkt)
Stand	11. Oktober 2026

Vertragsparteien

Auftraggeber (Verantwortlicher): das Unternehmen, für das der Workspace angelegt wird; Firma, Anschrift und vertretungsberechtigte Person ergeben sich aus den Angaben im Workspace oder aus der Unterschriftsseite dieses Vertrags – im Folgenden „Kunde"

Auftragnehmer (Auftragsverarbeiter): Flubber Pixels UG (haftungsbeschränkt), Florastraße 56, 40822 Mettmann, vertreten durch die Geschäftsführung – im Folgenden „Lymbe" Datenschutz-Kontakt: datenschutz@lymbe.ai · Telefon +49 2104 9129011

---

§ 1 Gegenstand und Dauer

(1) Lymbe stellt dem Kunden die KI-Plattform „Lymbe AI" bereit (Hauptvertrag: Nutzungsbedingungen in der jeweils gültigen Fassung). Dabei verarbeitet Lymbe personenbezogene Daten im Auftrag des Kunden. Dieser Vertrag regelt diese Auftragsverarbeitung.

(2) Nicht Gegenstand dieses Vertrags sind Daten, für die Lymbe selbst Verantwortlicher ist: Benutzerkonto, Anmeldung (auch über Google oder GitHub), Abrechnung und Zahlung. Dafür gilt die Datenschutzerklärung von Lymbe.

(3) Die Laufzeit entspricht der Laufzeit des Hauptvertrags. Eine Kündigung des Hauptvertrags beendet auch diesen Vertrag. § 3 Abs. 3, § 8, § 9 und § 12 Abs. 3 gelten über das Vertragsende hinaus.

§ 2 Art, Zweck und Umfang der Verarbeitung

(1) **Zweck:** Betrieb der vom Kunden eingerichteten KI-Assistenten und Funktionen: - **Kundenservice:** Assistenten auf Website, in Shops und – sofern vom Kunden verbunden – in Messengern; Beantwortung von Anfragen, Erfassung von Kontaktdaten (Leads), Terminanfragen, Übergabe an Mitarbeiter des Kunden (Live-Chat), Bewertungen - **Digitaler Mitarbeiter:** internes Wissen des Kunden (Dokumente, Gedächtnis), das Mitarbeiter des Kunden per Chat abfragen - **Frag Lymbe:** allgemeiner Chat-Assistent für Mitarbeiter des Kunden, auf Wunsch mit Websuche - **Abläufe:** vom Kunden eingerichtete Automationen, auch mit vom Kunden verbundenen Diensten (§ 5) - **Selbstlernen** (je Assistent vom Kunden ein- oder ausschaltbar, Auslieferungszustand aus): Übernahme von Inhalten aus Gesprächen der Kundenservice-Assistenten in das Gedächtnis - **Spracheingabe** (nur wenn vom Kunden genutzt): Umwandlung von Sprache in Text

(2) **Art der Verarbeitung:** Erheben, Speichern, Verändern, Auswerten durch KI-Sprachmodelle, Übermitteln an die in Anlage 2 genannten Unterauftragsverarbeiter, Löschen.

(3) **Datenkategorien und betroffene Personen:** siehe Anlage 3. Je nach Nutzung gehören dazu auch Daten Dritter, die der Kunde über verbundene Dienste einbringt (z. B. vollständige E-Mails und Anhänge aus Postfächern, Bestelldaten aus Shops, Kalenderteilnehmer).

(4) **Besondere Kategorien (Art. 9 DSGVO) und Berufsgeheimnisse (§ 203 StGB):** Lässt der Kunde solche Daten verarbeiten – etwa als Praxis, Therapieeinrichtung, Kanzlei oder Steuerberatung –, gilt zusätzlich § 12. Lymbe kann nicht verhindern, dass Endkunden solche Daten freiwillig in ein Gespräch eingeben; dafür ist der Kunde verantwortlich.

§ 3 Pflichten von Lymbe

(1) **Weisungsgebundenheit.** Lymbe verarbeitet die Daten nur auf dokumentierte Weisung des Kunden. Als Weisungen gelten dieser Vertrag, der Hauptvertrag und die Einstellungen, die der Kunde im Portal vornimmt – zum Beispiel das Einschalten des Selbstlernens oder eines Benachrichtigungsziels und das Verbinden eines Dienstes. Diese Einstellungen werden mit Zeitpunkt und Nutzer protokolliert. Weitere Weisungen erteilt der Kunde in Textform an datenschutz@lymbe.ai.

(2) **Hinweis bei rechtswidrigen Weisungen.** Hält Lymbe eine Weisung für rechtswidrig, informiert Lymbe den Kunden unverzüglich und darf die Ausführung bis zur Klärung aussetzen. Antwortet der Kunde nicht innerhalb von 5 Werktagen, gilt die Weisung als zurückgenommen.

(3) **Vertraulichkeit.** Alle Personen, die bei Lymbe oder seinen Unterauftragsverarbeitern Zugang zu Daten des Kunden haben, sind schriftlich auf Vertraulichkeit verpflichtet (Art. 28 Abs. 3 lit. b, Art. 29 DSGVO) und nach Anlage 5 zur Geheimhaltung verpflichtet.

(4) **Sicherheit.** Lymbe trifft die technischen und organisatorischen Maßnahmen nach Anlage 1 (Art. 32 DSGVO) und passt sie dem Stand der Technik an, ohne das Schutzniveau zu senken.

(5) **Support-Zugriff.** Lymbe und der technische Betreiber können im Rahmen von Betrieb und Support auf Inhalte des Kunden zugreifen. Ein solcher Zugriff erfolgt nur, wenn er zur Störungsbeseitigung oder auf Anfrage des Kunden erforderlich ist, nur nach vorheriger Freigabe durch die jeweils andere der beiden zugriffsberechtigten Personen von Lymbe und dem technischen Betreiber (Vier-Augen-Prinzip; bei Gefahr im Verzug mit unverzüglicher nachträglicher Information) und wird mit Zeitpunkt, Person, Grund, Umfang und Mandant protokolliert. Der Kunde erhält das Protokoll auf Anfrage. Zugriff zu anderen Zwecken findet nicht statt.

(6) **Kein Training.** Lymbe und seine Unterauftragsverarbeiter nutzen Inhalte des Kunden nicht, um KI-Modelle zu trainieren, zu testen oder zu verbessern. Lymbe hat sich dies von seinen KI-Anbietern vertraglich bestätigen lassen.

(7) **Unterstützung bei Betroffenenrechten.** Lymbe unterstützt den Kunden bei Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit und Widerspruch. Anfragen Betroffener, die bei Lymbe eingehen, leitet Lymbe innerhalb von drei Werktagen an den Kunden weiter und teilt dem Betroffenen nur mit, dass die Anfrage weitergeleitet wurde. Der Kunde kann Gespräche, Kontakte, Dokumente und Gedächtnis-Einträge im Portal selbst löschen und exportieren; Reste in Suchindex, Dateiablage und Ereignisspeicher löscht Lymbe auf Weisung innerhalb von 10 Werktagen.

(8) **Unterstützung bei Art. 32–36.** Lymbe unterstützt den Kunden bei der Sicherheit der Verarbeitung, bei Meldungen von Datenpannen (§ 7), bei einer Datenschutz-Folgenabschätzung und bei der Konsultation der Aufsichtsbehörde. Dafür stellt Lymbe eine Beschreibung der Plattform-Verarbeitung mit Risiken und Maßnahmen bereit, die der Kunde in seine Folgenabschätzung übernehmen kann.

(9) **Nachweise.** Lymbe stellt dem Kunden alle Informationen zur Verfügung, die zum Nachweis der Einhaltung dieses Vertrags erforderlich sind (§ 9).

(10) **Ort der Verarbeitung und Drittland.** Lymbe verarbeitet die Daten in Deutschland und in der EU. Übermittlungen in Länder außerhalb der EU/des EWR finden nur in den in Anlage 2 beschriebenen Fällen und auf der dort genannten Grundlage statt. Die Websuche in „Frag Lymbe" (Anlage 2 Nr. 5) ist Teil des Leistungsumfangs; mit dem Abschluss dieses Vertrags weist der Kunde Lymbe an, sie auszuführen. Der Suchbegriff wird vom KI-Modell nach fester Anweisung ohne Namen, Kontaktdaten und sonstige personenbezogene Angaben gebildet und vor der Übermittlung technisch geprüft; Lymbe prüft das vor jeder Freischaltung und regelmäßig mit Testfragen (Anlage 1). Gesprächsverlauf, Dokumente und Nutzeridentität werden nicht übermittelt. Der Kunde weist sein Team an, in Fragen an Frag Lymbe keine Personen zu nennen. Der Kunde kann die Websuche für seinen Workspace jederzeit durch Weisung in Textform abbestellen; Lymbe setzt die Weisung innerhalb von zwei Werktagen um.

(11) **Vergütung von Unterstützung.** Unterstützung nach Abs. 7, Abs. 8 und § 8 Abs. 4 erbringt Lymbe im Rahmen der Portal-Funktionen und der Standard-Dokumente ohne gesonderte Vergütung. Darüber hinausgehende Unterstützung und abweichende Weisungen vergütet der Kunde nach Aufwand; Lymbe weist vorher auf die Kosten hin.

§ 4 Unterauftragsverarbeiter

(1) Der Kunde genehmigt allgemein den Einsatz der in Anlage 2 genannten Unterauftragsverarbeiter. Lymbe setzt sie unmittelbar oder über den technischen Betreiber 26lab.io ein; in beiden Fällen stellt Lymbe durch schriftliche Verträge sicher, dass jeder Unterauftragsverarbeiter zu Pflichten verpflichtet ist, die den Pflichten aus diesem Vertrag entsprechen (Art. 28 Abs. 4 DSGVO).

(2) **Änderungen.** Lymbe informiert den Kunden mindestens **14 Tage** vor dem Einsatz eines neuen oder dem Wechsel eines Unterauftragsverarbeiters per E-Mail an die im Portal hinterlegte Adresse. Der Kunde kann innerhalb dieser Frist widersprechen. Kann Lymbe den Unterauftragsverarbeiter für den Workspace des Kunden nicht aussparen, teilt Lymbe das innerhalb von 5 Werktagen mit; der Kunde kann dann bis zum Zeitpunkt des Einsatzes den Hauptvertrag außerordentlich kündigen, vorausbezahlte Entgelte werden anteilig erstattet. Kündigt der Kunde nicht, gilt der Widerspruch als zurückgenommen. § 12 Abs. 3 bleibt unberührt. Der Wegfall eines Unterauftragsverarbeiters wird ohne Frist mitgeteilt.

(3) **Drittland.** Übermittelt ein Unterauftragsverarbeiter Daten in ein Land außerhalb der EU/des EWR, geschieht das nur auf der in Anlage 2 genannten Grundlage: Angemessenheitsbeschluss der EU-Kommission, EU-US Data Privacy Framework (Zertifizierung des US-Unternehmens) oder Standardvertragsklauseln der EU-Kommission (Art. 46 Abs. 2 lit. c DSGVO).

(4) Die aktuelle Liste ist jederzeit unter lymbe.ai/avv abrufbar. Frühere Fassungen bleiben dort mit Datum einsehbar.

§ 5 Vom Kunden verbundene Dienste

(1) Der Kunde kann im Portal eigene Konten und Dienste verbinden – zum Beispiel Messenger, Kalender, Shops, E-Mail-Postfächer, Benachrichtigungsziele (Slack, Microsoft Teams, eigene Webadresse), Adressen, die Lymbe auf Weisung des Kunden abruft (Website-Crawl, Schnittstellen-Import), sowie alle weiteren Dienste, die über Bausteine der Abläufe verbunden werden können. Welche Anbieter das sind und wo sie sitzen, zeigt das Portal beim Verbinden an.

(2) Diese Dienste beauftragt der **Kunde**, nicht Lymbe. Sie sind keine Unterauftragsverarbeiter von Lymbe. Lymbe übermittelt Daten an sie und empfängt Daten von ihnen ausschließlich auf Grund der Verbindung, die der Kunde hergestellt hat; die Verbindung gilt als Weisung nach § 3 Abs. 1.

(3) Der Kunde stellt sicher, dass - er mit dem jeweiligen Anbieter die erforderlichen Verträge geschlossen hat (insbesondere einen Auftragsverarbeitungsvertrag, wo der Anbieter im Auftrag des Kunden handelt), - für Anbieter außerhalb der EU/des EWR eine Grundlage für die Übermittlung besteht, - die betroffenen Personen – auch Dritte wie E-Mail-Absender, Kalenderteilnehmer oder Shop-Kunden – nach Art. 13 und 14 DSGVO informiert sind, - verbundene Postfächer ausschließlich dienstlich genutzt werden, - Zugangsschlüssel mit möglichst geringen Rechten erteilt werden.

(4) Lymbe speichert Zugangsdaten verbundener Dienste verschlüsselt und verwendet sie nur für die vom Kunden eingerichteten Funktionen.

(5) **Messenger (WhatsApp).** Bei WhatsApp stellt Lymbe die technische Anbindung über eine eigene Anwendung bei Meta bereit und speichert die Zugangsschlüssel des Kunden. Meta verarbeitet die Nachrichten nach den WhatsApp Business Data Processing Terms als Auftragsverarbeiter des Kunden; die Übermittlung in die USA erfolgt über das EU-US Data Privacy Framework. Messenger-Nutzer erhalten in der ersten Antwort einen Hinweis auf die KI und auf die Datenschutzerklärung des Kunden; den Text stellt Lymbe bereit.

§ 6 Pflichten des Kunden

(1) Der Kunde ist Verantwortlicher im Sinne der DSGVO. Er stellt sicher, dass für die Verarbeitung eine Rechtsgrundlage besteht und die Betroffenen informiert sind. Lymbe stellt dafür Textbausteine bereit (für die Datenschutzerklärung des Kunden, die Information der Beschäftigten und die Hinweise im Chat); der Kunde setzt sie ein.

(2) Der Kunde setzt die Assistenten nur für die im Hauptvertrag beschriebenen Zwecke ein. Der Kunde ist Betreiber der KI-Systeme im Sinne der KI-Verordnung (EU) 2024/1689. Lymbe kennzeichnet die Assistenten im Website-Chatfenster und im Portal als KI (Art. 50 KI-VO); für andere Kanäle stellt Lymbe Hinweistexte bereit, die der Kunde einsetzt. Für die Inhalte eigener Fähigkeiten, Prompts und Abläufe ist der Kunde verantwortlich.

(3) Setzt der Kunde Mitarbeiter als Nutzer ein (Digitaler Mitarbeiter, Frag Lymbe, Live-Chat), informiert er diese nach Art. 13 DSGVO und beachtet etwaige Mitbestimmungsrechte. Er gibt Admins und Live-Chat-Agenten nur so viele Einsichtsrechte, wie für ihre Aufgabe erforderlich.

(4) Schaltet der Kunde das Selbstlernen ein, prüft er, ob die Übernahme von Gesprächsinhalten in das Gedächtnis mit dem ursprünglichen Zweck vereinbar ist (Art. 6 Abs. 4 DSGVO), informiert die Betroffenen und löscht Einträge, die nicht benötigt werden.

(5) Der Kunde prüft Inhalte, die er aus Frag Lymbe (insbesondere aus der Websuche) in das Gedächtnis übernimmt, auf Richtigkeit und Zulässigkeit.

(6) Der Kunde hält die im Portal hinterlegte E-Mail-Adresse aktuell. Mitteilungen an diese Adresse gelten als zugegangen. Im Portal gilt der Inhaber des Workspace als weisungsberechtigt; weitere Ansprechpartner kann der Kunde nach Anlage 4 benennen.

(7) Der Kunde stellt sicher, dass nur vertretungsberechtigte Personen einen Workspace anlegen. Bestätigt eine nicht berechtigte Person, gilt der Vertrag mit der ersten Nutzung als genehmigt.

(8) **Sperrrecht.** Verarbeitet der Kunde erkennbar Daten unter Verstoß gegen § 5 Abs. 3 oder § 12, kann Lymbe die betreffende Funktion nach Hinweis und Ablauf von 5 Werktagen sperren, bis der Verstoß behoben ist.

§ 7 Verletzungen des Schutzes personenbezogener Daten

(1) Lymbe meldet dem Kunden jede Verletzung des Schutzes personenbezogener Daten, die Daten des Kunden betrifft, unverzüglich, in der Regel innerhalb von **24 Stunden** nach Kenntnis bei Lymbe oder beim technischen Betreiber, an die im Portal hinterlegte E-Mail-Adresse. Die Meldung enthält, soweit bekannt: Art der Verletzung, betroffene Datenkategorien und Personen, wahrscheinliche Folgen, ergriffene Maßnahmen, Ansprechpartner. Informationen, die noch nicht vorliegen, werden nachgereicht.

(2) Der Kunde entscheidet über die Meldung an die Aufsichtsbehörde (Art. 33) und die Benachrichtigung der Betroffenen (Art. 34). Lymbe unterstützt dabei.

(3) Lymbe dokumentiert alle Verletzungen einschließlich der nicht meldepflichtigen (Art. 33 Abs. 5 DSGVO).

§ 8 Löschung und Rückgabe

(1) **Während der Laufzeit** gelten folgende Fristen, soweit der Kunde Daten nicht vorher selbst löscht. Der Kunde kann in seinem Workspace kürzere Fristen festlegen.

Daten	Frist
Gespräche der Kundenservice-Assistenten (Website, Shop, Messenger, einschließlich Live-Chat), des Digitalen Mitarbeiters und von Frag Lymbe	automatisch 90 Tage nach der letzten Nachricht; der Verlauf einer aktiven geplanten Aufgabe bleibt, solange die Aufgabe aktiv ist
Ausgeführte Abläufe im Portal (Eingaben und Ergebnis eines Laufs)	automatisch mit der Frist der Gespräche, 90 Tage
Schrittprotokolle im Ablauf-Kern, einschließlich Daten, die ein Ablauf aus verbundenen Diensten abruft (E-Mails samt Anhängen, Bestellungen, Termine) – soweit nicht vom Kunden in Kontakte, Dokumente oder Gedächtnis übernommen	automatisch spätestens 30 Tage
Ereignisdaten der Messenger-Anbindung	automatisch 30 Tage
Sprachaufnahmen	nur zur Umwandlung in Text; keine Speicherung
Kontakte (Leads)	automatisch 90 Tage nach der letzten Bearbeitung
Termine	automatisch 90 Tage nach dem Termin
Bewertungen	mit dem Gespräch
Nachweise über Einwilligung oder Widerruf im Chat (ohne Chatinhalt)	automatisch nach drei Jahren
Hochgeladene Dokumente, Gedächtnis-Einträge	bis zur Löschung durch den Kunden im Portal
Zugriffs- und Betriebsprotokolle	automatisch 14 Tage; Fehlerprotokoll 30 Tage
Datensicherungen (verschlüsselte Datenbank- und Datei-Sicherungen, auch als Kopie an einem zweiten Standort, und Server-Abbilder des Hosters)	je 7 Tage, dann automatisch überschrieben; weil die Server-Abbilder auch die Datenbank-Sicherungen enthalten, können gelöschte Daten bis zu 14 Tage in Sicherungen verbleiben

(2) **Datensicherungen.** Eine Einzel-Löschung aus Datensicherungen ist technisch nicht möglich. Gelöschte Daten verschwinden mit Ablauf der Sicherungsfrist auch aus den Sicherungen. Wird eine Sicherung zurückgespielt, löscht Lymbe zuvor gelöschte Daten erneut.

(3) **Nach Vertragsende** (bei einer Testphase ohne Tarif: nach der Sperre nach § 4 der Nutzungsbedingungen) löscht Lymbe alle Daten des Kunden innerhalb von 30 Tagen, einschließlich der Kopien im Vektorspeicher (Suchindex der Wissensdatenbank), in der Dateiablage und im

Ereignisspeicher; Datensicherungen sind spätestens 44 Tage nach Vertragsende überschrieben. Ausgenommen sind die Protokolle über Vertragsabschluss, Fassungen und Weisungen, die Lymbe zum Nachweis dieses Vertrags drei Jahre aufbewahrt. Auf Verlangen bestätigt Lymbe die Löschung schriftlich.

(4) **Rückgabe.** Bis zum Vertragsende und für weitere 14 Tage danach (Nur-Lese-Zugang) kann der Kunde Gespräche, Kontakte, Dokumente und Gedächtnis-Einträge im Portal exportieren – in gängigen maschinenlesbaren Formaten (JSON oder CSV), Dokumente im Originalformat. Auf Verlangen stellt Lymbe einen Gesamtexport bereit.

§ 9 Kontrollrechte

(1) Der Kunde kann die Einhaltung dieses Vertrags überprüfen. Dazu stellt Lymbe zunächst Nachweise bereit: Anlage 1, das aktuelle Dienstleisterverzeichnis, Zertifikate und Prüfberichte der Unterauftragsverarbeiter sowie Protokolle, soweit sie den Workspace des Kunden betreffen.

(2) Reichen die Nachweise nicht aus, kann der Kunde oder ein von ihm beauftragter, zur Verschwiegenheit verpflichteter Prüfer nach Ankündigung von mindestens **5 Werktagen** während der üblichen Geschäftszeiten eine Prüfung durchführen, höchstens einmal jährlich, es sei denn, ein konkreter Anlass liegt vor. Ein Zutrittsrecht zu Rechenzentren der Unterauftragsverarbeiter besteht nicht; insoweit genügen deren Zertifikate und Prüfberichte. Für Prüfungen ohne Anlass kann Lymbe einen angemessenen Aufwandsersatz verlangen.

(3) Prüfungen durch Aufsichtsbehörden sind jederzeit zulässig. Lymbe unterstützt sie.

§ 10 Haftung und Freistellung

(1) Gegenüber betroffenen Personen haften die Parteien nach Art. 82 DSGVO.

(2) Im Verhältnis der Parteien zueinander gelten die Haftungsregeln des Hauptvertrags; der Ausgleich nach Art. 82 Abs. 5 DSGVO bleibt unberührt.

(3) Der Kunde stellt Lymbe von Ansprüchen Dritter und Bußgeldern frei, soweit sie darauf beruhen, dass der Kunde ohne Rechtsgrundlage, ohne Information der Betroffenen, unter Verstoß gegen § 5 Abs. 3, § 6 oder § 12 oder aufgrund einer rechtswidrigen Weisung hat verarbeiten lassen.

§ 11 Schlussbestimmungen

(1) Dieser Vertrag geht bei Widersprüchen den Nutzungsbedingungen vor, soweit es um die Verarbeitung personenbezogener Daten geht.

(2) **Änderungen dieses Vertrags** teilt Lymbe mit einer Frist von 30 Tagen mit. Der Kunde bestätigt die neue Fassung im Portal; ohne Bestätigung gilt die bisherige Fassung weiter, bis Lymbe den Hauptvertrag ordentlich kündigt. Fassungen und Bestätigungen werden mit Zeitpunkt, Person und Adresse protokolliert.

(3) Es gilt deutsches Recht. Gerichtsstand ist Düsseldorf, soweit der Kunde Kaufmann ist.

(4) Sollte eine Bestimmung unwirksam sein, bleibt der Vertrag im Übrigen wirksam.

(5) **Abschluss.** Dieser Vertrag wird elektronisch durch Bestätigung im Portal beim Anlegen des Workspace geschlossen (Art. 28 Abs. 9 DSGVO) oder durch Unterzeichnung der Unterschriftsseite. Lymbe protokolliert Fassung, Zeitpunkt, Name, E-Mail-Adresse und IP-Adresse der bestätigenden Person sowie die Angaben zum Kunden.

§ 12 Gesundheitsdaten, besondere Kategorien und Berufsgeheimnis

(0) **Anwendungsbereich.** Dieser Paragraf gilt, soweit der Kunde besondere Kategorien personenbezogener Daten (Art. 9 Abs. 1 DSGVO, insbesondere Gesundheitsdaten) verarbeiten lässt oder bei ihm Personen tätig sind, die einem Berufsgeheimnis unterliegen (§ 203 StGB – zum Beispiel Ärzte, Psychotherapeuten, Psychologen, Heilberufe mit staatlich geregelter Ausbildung, staatlich anerkannte Sozialpädagogen und Sozialarbeiter, Rechtsanwälte, Notare, Steuerberater).

(1) **Rechtsgrundlage.** Für Patienten bzw. Mandanten in Betreuung und für Personen, die eine Behandlung oder ein Mandat anfragen, ist die Verarbeitung gesetzlich gedeckt – Art. 9 Abs. 2 lit. h DSGVO in Verbindung mit § 22 Abs. 1 Nr. 1 lit. b BDSG (medizinische Diagnostik, Versorgung oder Behandlung im Gesundheits- oder Sozialbereich und die Verwaltung dieser Dienste durch Personen, die einer Geheimhaltungspflicht unterliegen; Lymbe unterliegt nach Abs. 3 einer entsprechenden Geheimhaltungspflicht). Nur wo kein Behandlungs- oder Mandatsbezug besteht, holt der Kunde eine ausdrückliche Einwilligung ein (Art. 9 Abs. 2 lit. a DSGVO). Der Kunde stellt sicher, dass eine dieser Grundlagen vorliegt.

(2) **Kein Primärsystem, kein Medizinprodukt.** Die gesetzliche Behandlungs- oder Mandatsdokumentation (z. B. § 630f BGB, Berufsordnungen) führt der Kunde in seinem eigenen System; Aufbewahrungspflichten erfüllt er dort. Lymbe dient der Beantwortung von Anfragen, der Organisation und dem Wissensmanagement und ersetzt keine fachliche Beurteilung. Entscheidungen über Diagnostik, Behandlung und Mandatsführung trifft der Kunde. Die Löschfristen des § 8 gelten unverändert.

(3) **Geheimhaltung nach § 203 StGB.** Lymbe ist mitwirkende Person im Sinne des § 203 Abs. 3 Satz 2 StGB; der Kunde darf Lymbe Geheimnisse offenbaren, soweit dies für die Nutzung der Plattform erforderlich ist. Lymbe verpflichtet sich zur Geheimhaltung aller Geheimnisse, die ihm bei der Ausübung oder bei Gelegenheit seiner Tätigkeit bekannt werden, und unterliegt damit einer dem Berufsgeheimnis entsprechenden Geheimhaltungspflicht (§ 22 Abs. 1 Nr. 1 lit. b BDSG, § 203 Abs. 4 StGB). Die Personen mit Zugang zu Daten des Kunden geben die Verpflichtungserklärung nach Anlage 5 ab; auf Anfrage nennt Lymbe sie dem Kunden und stellt ihm eine Kopie der Erklärung zur Verfügung. Lymbe zieht den technischen Betreiber 26lab.io und die Unterauftragsverarbeiter nach Anlage 2 hinzu, offenbart ihnen Geheimnisse nur, soweit es für ihre Tätigkeit erforderlich ist, und verpflichtet sie zur Geheimhaltung (§ 203 Abs. 4 Satz 2 Nr. 2 StGB) – 26lab.io durch ausdrückliche Verpflichtung und Anlage 5, die Cloud-Anbieter durch die Geheimhaltungspflichten in deren Verträgen, deren Vorliegen Lymbe vor dem Einsatz für Daten nach diesem Paragrafen prüft und dokumentiert. Einen neuen Unterauftragsverarbeiter setzt Lymbe für solche Daten erst ein, wenn er zur Geheimhaltung verpflichtet ist. Lymbe gibt Geheimnisse nicht an Dritte weiter, auch nicht an Behörden, es sei denn, eine gesetzliche Pflicht besteht; Lymbe beruft sich auf das abgeleitete Zeugnisverweigerungsrecht und den Beschlagnahmeschutz als mitwirkende Person (§ 53a, § 97 StPO), solange der Kunde als Berufsgeheimnisträger nicht von der Schweigepflicht entbindet, und informiert den Kunden vorab, soweit zulässig.

(4) **Websuche, Selbstlernen, verbundene Dienste.** Die Websuche übermittelt nach § 3 Abs. 10 keine personenbezogenen Angaben. Der Kunde weist sein Team dennoch an, in Frag Lymbe keine Patienten- oder Mandantennamen zu nennen. Schaltet der Kunde das Selbstlernen für einen Assistenten ein, prüft er übernommene Einträge regelmäßig (§ 6 Abs. 4). Benachrichtigungsziele, Kalender und Postfächer verbindet der Kunde nur mit dienstlichen Konten von Anbietern, mit denen er einen Auftragsverarbeitungsvertrag hat (§ 5 Abs. 3); er beachtet, dass schon ein Termin oder eine Anfrage ein Gesundheitsdatum sein kann.

(5) **Pflichten des Kunden.** - Er informiert Patienten bzw. deren Sorgeberechtigte und Mandanten nach Art. 13 DSGVO über den Einsatz von Lymbe (Textbausteine von Lymbe). - Er richtet den Website-Assistenten so ein, dass er sich als KI zu erkennen gibt, keine Diagnosen stellt, keine Behandlungs- oder Rechtsempfehlungen gibt, keine Notfälle bearbeitet, Gesundheitsdetails nicht aktiv abfragt, Minderjährige an ihre Sorgeberechtigten verweist und von ihnen keine Kontaktdaten erfasst, und nicht drängt oder Entscheidungen beeinflusst (Art. 5 Abs. 1 lit. b KI-VO). - Er löscht Kontakte aus dem Website-Chat, sobald das Anliegen erledigt oder eine Behandlung begonnen ist, und lässt Benachrichtigungen nur an dienstliche Postfächer gehen. - Er verpflichtet seine Mitarbeiter zur Vertraulichkeit, informiert und schult sie (§ 22 Abs. 2 Satz 2 Nr. 3 BDSG, Art. 4 KI-VO). - Er führt vor Beginn der Verarbeitung eine Datenschutz-Folgenabschätzung durch (Art. 35 DSGVO); Lymbe liefert eine Vorlage mit ausgefülltem Technik-Teil. Lymbe weist darauf hin, dass eine DSFA-pflichtige Verarbeitung nach § 38 Abs. 1 Satz 2 BDSG die Benennung eines Datenschutzbeauftragten auslösen kann. - Er nimmt nur Personen mit Behandlungs- bzw. Mandatsbezug als Mitglieder in den Workspace auf, solange dort Patienten- oder Mandantendokumente liegen – alle Mitglieder eines Workspace können die hochgeladenen Dokumente abfragen. Wo es die Arbeit nicht behindert, lädt er Dokumente mit Kürzeln statt Klarnamen hoch (§ 22 Abs. 2 Satz 2 Nr. 6 BDSG). - Er lädt nur Inhalte hoch, die für die Arbeit seines Teams erforderlich sind, und prüft mindestens jährlich, welche Dokumente und Gedächtnis-Einträge noch benötigt werden.

(6) **Vorfälle.** Bei Verletzungen, die Daten nach diesem Paragrafen betreffen, informiert Lymbe den Kunden zusätzlich telefonisch unter der im Portal hinterlegten Nummer, wenn die E-Mail nicht innerhalb von 4 Stunden bestätigt wird. Lymbe weist darauf hin, dass bei Gesundheitsdaten regelmäßig ein hohes Risiko und damit eine Benachrichtigung der Betroffenen (Art. 34 DSGVO) anzunehmen ist.

(7) **Freistellung.** § 10 Abs. 3 gilt auch für Verstöße des Kunden gegen Abs. 1, 4 und 5.

Unterschriftsseite

Kunde (Firma): _____

Anschrift: _____

Vertretungsberechtigte Person (Name, Funktion): _____

E-Mail-Adresse für Mitteilungen nach diesem Vertrag: _____

Telefonnummer für Meldungen nach § 7 und § 12 Abs. 6: _____

Workspace-Name im Portal: _____

Ort, Datum: _____ Unterschrift Kunde:

_____

Flubber Pixels UG (haftungsbeschränkt), Florastraße 56, 40822 Mettmann

Ort, Datum: _____ Unterschrift:

_____ (Dennis Link, Projektleiter Lymbe AI)

Anlage 1 – Technische und organisatorische Maßnahmen (Kurzfassung)

Ausführliche Beschreibung auf Anfrage. Grundlage ist das Dienstleisterverzeichnis, das vierteljährlich am laufenden System nachgemessen wird.

Vertraulichkeit - Mandantentrennung: eigene Datenbank je Kunde; Suchindex und Dateiablage mandantengetrennt - Verschlüsselung: TLS 1.2+ bei der Übertragung; Zugangsdaten verbundener Dienste und Datensicherungen verschlüsselt (AES-256), Passwörter nur als Hash; Rechenzentrum nach ISO/IEC 27001 zertifiziert - Zugriffskontrolle: Rollen im Portal (Inhaber, Mitglied, Nur-Ansehen); Admin-Zugänge mit Mehr-Faktor-Anmeldung; Support-Zugriff nur bei Störung oder Anfrage, mit Freigabe, protokolliert - Vertraulichkeits- und Geheimhaltungsverpflichtung aller Personen mit Zugriff (Anlage 5)

Integrität - Eingehende E-Mails werden bereinigt angezeigt (keine Nachladung fremder Inhalte) - Vom Kunden eingetragene Abrufadressen werden geprüft (kein Zugriff auf interne Netze, Begrenzung von Zeit und Größe) - Rechenfunktionen laufen in einem abgeschotteten Bereich ohne Netzzugang - Eigene Missbrauchsprüfung im Chat-Widget ohne Einbindung Dritter - Suchbegriffe für die Websuche werden nach fester Anweisung ohne personenbezogene Angaben gebildet; regelmäßige Prüfung mit Testfragen

Verfügbarkeit - Tägliche verschlüsselte Datensicherung, 7 Tage Aufbewahrung, Kopie an einem zweiten Standort in Deutschland, vom Server aus nicht löschbar; wöchentliche Wiederherstellungsprobe - Ratenbegrenzung (Begrenzung der Anfragen je Zeit) gegen Überlastung und Missbrauch

Verfahren - Änderungen an Datenwegen werden vor Umsetzung dokumentiert und freigegeben - Vorfall-Prozess mit Meldekette (§ 7) - Verwaltung der Verschlüsselungszertifikate automatisiert

Anlage 2 – Unterauftragsverarbeiter

Stand Fassung 1.7. Lymbe setzt die Anbieter unmittelbar oder über 26lab.io ein.

Nr	Unternehmen	Leistung	Daten	Standort	Drittland-Grundlage
1	26lab.io, Inhaber Christian Gudermann, Hasselbeckstr. 37, 40822 Mettmann	Technischer Betrieb der Plattform und der KI-Infrastruktur	alle	Deutschland	–
2	Hetzner Online GmbH, Industriestr. 25, 91710 Gunzenhausen	Server, Datenbanken, Speicher, Sicherungen	alle	Deutschland (Nürnberg; Sicherungskopie Falkenstein)	–
3	Schwarz Digits Cloud GmbH & Co. KG (STACKIT), Am Campus 1, 74177 Bad Friedrichshall	KI-Sprachmodelle (Antworten, Einordnung von Nachrichten, Bilder), Umwandlung von Text in Suchvektoren für die Wissenssuche	Gesprächsinhalte, Dokumente, E-Mail-Texte, Bilder	EU/EWR (vertraglich); Rechenzentrum in Deutschland nach Angabe des Anbieters	–
4	Microsoft Ireland Operations Ltd., One Microsoft Place, Dublin 18	Azure OpenAI – Werkstatt für Abläufe (Beschreibungstexte und Ablaufdefinitionen, Zugangsdaten vorher maskiert); Azure AI Speech – Spracheingabe, nur wenn genutzt	Beschreibungstexte; Sprachaufnahmen. Microsoft prüft Ein- und Ausgaben der Werkstatt automatisiert auf Missbrauch; nur auffällige Inhalte werden vorübergehend für eine Prüfung durch Microsoft-Mitarbeiter im EWR gespeichert, in der Geografie der Ressource; kein Training. Sprachaufnahmen werden nicht gespeichert	Spracheingabe: Deutschland; Werkstatt: EU-Datenzone	Rest-Übermittlungen (Support, Telemetrie) über Standardvertragsklauseln im Microsoft-DPA und EU-US Data Privacy Framework
5	OpenAI Ireland Ltd., 1st Floor, The Liffey Trust Centre, 117–126 Sheriff Street Upper, Dublin 1	Websuche in „Frag Lymbe"	Der vom Modell nach fester Anweisung ohne personenbezogene Angaben gebildete Suchbegriff und die Landesangabe „DE" (§ 3 Abs. 10). Nicht übermittelt: Gesprächsverlauf, Dokumente, Nutzeridentität. OpenAI kann den Suchbegriff bis zu 30 Tage zur Missbrauchsüberwachung speichern; kein Training	Irland; Verarbeitung ggf. USA	Standardvertragsklauseln im OpenAI-DPA

Historie: Fassung 1.2 (17.09.2026): Cloudflare Germany GmbH (Bot-Prüfung im Widget) entfernt, ersetzt durch eigene Prüfung. Fassung 1.6 (05.10.2026): OpenAI-Auftragsverarbeitungsvertrag mit Standardvertragsklauseln abgeschlossen; Speicherung zur Missbrauchsüberwachung bei Microsoft und OpenAI ergänzt; Stripe Payments Europe aus der Liste entfernt – Zahlungsdienstleister für die

Abrechnung zwischen Lymbe und Kunde, keine Auftragsverarbeitung von Kundendaten (siehe Datenschutzerklärung). Fassung 1.7 (11.10.2026): Fristen in § 8 Abs. 1 an den Betrieb angepasst (ausgeführte Abläufe, Kontakte und Termine 90 Tage, Nachweise drei Jahre, Sicherungen bis 14 Tage, nach Vertragsende 44 Tage); Verschlüsselung und Sicherungskopie in Anlage 1 präzisiert; Anlage 2: STACKIT vertraglich EU/EWR, Microsoft-Missbrauchsüberwachung ohne feste Frist, Spracheingabe Deutschland, Hetzner-Sicherungskopie Falkenstein; § 11 Abs. 5 an die richtige Stelle gesetzt.

Nicht in dieser Liste, weil vom Kunden selbst beauftragt (§ 5): Meta (WhatsApp), Google und Microsoft (Kalender, Postfach), Calendly, Cal.com, Shopify, Shopware, WooCommerce, Slack und alle weiteren Dienste, die der Kunde im Portal verbindet. Microsoft erscheint daher zweimal: als Unterauftragsverarbeiter von Lymbe (Nr. 4) und – nur wenn der Kunde ein Microsoft-Konto verbindet – als Dienst des Kunden.

Anlage 3 – Verarbeitungsübersicht je Bereich

Bereich	Datenkategorien	Betroffene Personen	Empfänger (Anlage 2)
Kundenservice (Website-Widget, Shop, Messenger)	Gesprächsinhalte und Zeitpunkt · Referrer (Adresse der aufgerufenen Seite) und IP-Adresse des Besuchers bei jedem Seitenaufruf mit Widget, bei eingeschalteter Besuchsanalyse zusätzlich Seitenadresse, Scrolltiefe und Sitzungskennung ohne Personenbezug · Kontaktdaten aus Lead-Erfassung (Name, E-Mail, Telefon) · Terminwünsche · Bewertungen · bei Messenger: Telefonnummer, Profilname, Nachrichtentext	Website-Besucher, Endkunden und Interessenten des Kunden; Messenger-Nutzer; bei § 12-Kunden Patienten, Sorgeberechtigte, Mandanten	1, 2, 3
Live-Chat	Gesprächsverlauf, Name/Kürzel des bearbeitenden Mitarbeiters, Wartezeiten	Endkunden, Mitarbeiter des Kunden	1, 2
Selbstlernen (nur wenn eingeschaltet)	Aus Gesprächen übernommene Inhalte als Gedächtnis-Einträge	Endkunden	1, 2, 3
Digitaler Mitarbeiter	Hochgeladene Dokumente und ihre Inhalte · Gedächtnis-Einträge · Fragen und Antworten der Mitarbeiter, Zeitpunkt, Nutzer	Mitarbeiter des Kunden; Personen, die in Dokumenten vorkommen (Kunden, Lieferanten, Beschäftigte; bei § 12-Kunden Patienten, Mandanten, Angehörige)	1, 2, 3
Frag Lymbe	Fragen und Antworten, Zeitpunkt, Nutzer · bei Websuche: Suchbegriff ohne Personenbezug	Mitarbeiter des Kunden; Personen, die in Fragen genannt werden	1, 2, 3; bei Websuche 5
Abläufe	Ablaufdefinitionen, Laufdaten · Daten aus verbundenen Diensten (E-Mails samt Anhängen, Bestellungen, Termine, Kontakte) · Beschreibungstexte für die Werkstatt	Kommunikationspartner des Kunden (Absender, Shop-Kunden, Kalenderteilnehmer), Mitarbeiter des Kunden	1, 2, 3, 4 (Werkstatt)
Spracheingabe (nur wenn genutzt)	Sprachaufnahme (nur zur Umwandlung), Transkript	Nutzer des Portals	4 (Aufnahme); 1, 2, 3 (Transkript)
Weisungs- und Nutzungsprotokoll	Name, E-Mail, Rolle der Team-Mitglieder, Zeitpunkt von Einstellungen und Freigaben	Mitarbeiter des Kunden	1, 2

Anlage 4 – Ansprechpartner

Seite	Rolle	Kontakt
Kunde	Weisungsberechtigt (Inhaber des Workspace)	aus dem Workspace oder der Unterschriftsseite (Name, E-Mail, Telefon)
Kunde	Datenschutz-Ansprechpartner, falls abweichend	im Portal hinterlegbar
Lymbe	Datenschutz-Ansprechpartner, Empfänger von Weisungen und Meldungen	Flubber Pixels UG, datenschutz@lymbe.ai, +49 2104 9129011
Unterauftragsverarbeiter	Technischer Betrieb, Meldung technischer Vorfälle an Lymbe	26lab.io, Christian Gudermann, hello@26lab.io

Änderungen teilen die Parteien in Textform mit.

Anlage 5 – Verpflichtungserklärung nach § 203 Abs. 4 StGB und Art. 29 DSGVO

Ich, die/der Unterzeichnende, tätig für die Flubber Pixels UG (haftungsbeschränkt) bzw. für 26lab.io, wirke an der beruflichen Tätigkeit von Berufsgeheimnisträgern mit, die die Plattform Lymbe AI nutzen (§ 203 Abs. 3 Satz 2 StGB), und habe Zugang zu personenbezogenen Daten der Kunden von Lymbe AI.

Ich verpflichte mich,

1. alle Geheimnisse und personenbezogenen Daten, die mir bei der Ausübung oder bei Gelegenheit dieser Tätigkeit bekannt werden – insbesondere Gesundheitsdaten, Angaben zu Patienten, Mandanten und deren Angehörigen –, nicht unbefugt zu offenbaren oder zu verarbeiten, weder während noch nach Beendigung meiner Tätigkeit;
2. auf Inhalte von Kunden nur zuzugreifen, wenn dies zur Störungsbeseitigung oder auf Anfrage des Kunden erforderlich ist, nur mit vorheriger Freigabe und jeden Zugriff zu protokollieren;
3. weitere Personen nur hinzuzuziehen, wenn sie ebenfalls zur Geheimhaltung verpflichtet wurden (§ 203 Abs. 4 Satz 2 Nr. 2 StGB);
4. Kundeninhalte nicht für eigene Zwecke zu verwenden, insbesondere nicht zum Training oder Testen von KI-Modellen, nicht zu kopieren und nicht in private Geräte, Konten oder Entwicklungsumgebungen zu übernehmen;
5. die technischen und organisatorischen Maßnahmen einzuhalten und Verstöße, Sicherheitslücken und Vorfälle unverzüglich an datenschutz@lymbe.ai zu melden;
6. bei Beendigung meiner Tätigkeit alle Daten, Zugänge und Kopien zurückzugeben bzw. nachweislich zu löschen.

Ich bin darüber belehrt worden, dass die unbefugte Offenbarung eines fremden Geheimnisses nach § 203 Abs. 4 StGB mit Freiheitsstrafe bis zu einem Jahr oder mit Geldstrafe bestraft wird, bei Handeln gegen Entgelt oder in Bereicherungs- oder Schädigungsabsicht mit Freiheitsstrafe bis zu zwei Jahren (§ 203 Abs. 6 StGB), dass die unbefugte Verarbeitung personenbezogener Daten nach § 42 BDSG strafbar sein kann, und dass dies auch für mich als mitwirkende Person gilt. Ich weiß, dass ich als mitwirkende Person ein abgeleitetes Zeugnisverweigerungsrecht habe (§ 53a StPO), über dessen Ausübung der Berufsgeheimnisträger entscheidet, und dass ich ohne dessen Entbindung über die Geheimnisse auch vor Gericht schweige.

Name: _____ Firma: _____

Ort, Datum: _____ Unterschrift:

_____

Belehrt durch: Flubber Pixels UG (haftungsbeschränkt), Marion Schagen, Geschäftsführung:

_____